

CYBERSECURITY FOUNDATIONS

Applied Cybersecurity Workshop

Building a Security & Data Protection Program

Applying concepts from Lesson - Securing Computing Resources & Asset Management - and Lesson - Data Protection Strategies

Workshop Objectives

This project brings together the two lessons you've just covered. Every task below maps to one or more lesson objectives — use your notes and LMS as references while you work.

From Lesson 1 — Data Protection Strategies

- Explain data classification and labeling and why they matter
- Differentiate between encryption at rest and in transit
- Describe data protection techniques: hashing, tokenization, and data masking
- Identify DLP strategies and tools
- Recognize how regulations like HIPAA, GDPR, and PCI-DSS influence data protection

From Lesson 2 — Securing Computing Resources & Asset Management

- Apply security hardening techniques to various computing resources
- Understand the importance of secure configuration and patch management
- Track IT assets through their full lifecycle
- Classify assets — hardware, software, and data — to prioritize protection
- Describe how Endpoint Detection and Response (EDR) enhances visibility and control

How This Works

1. Read your scenario carefully. Just like the real-world scenarios from lecture, each one has a hidden risk buried in the asset list — part of your job is to find it.
2. Work through all 7 parts of the worksheet as an individual; however, collaborate and discuss concepts and approaches with your teammates.
3. Submit your completed worksheet packet at the end of the session.

A note on “correct” answers

Several tasks in this project are intentionally open-ended — just like some of the scenario exercises from lecture. There is often more than one defensible answer. You'll be evaluated on whether your reasoning correctly applies the concepts from both lessons, not on matching one exact answer key.

Your Scenario

SCENARIO

NorthPeak Payments

A 60-person, fast-scaling fintech startup processing card payments for small businesses.

Organization Profile

NorthPeak Payments processes credit and debit card payments for small-business clients. The engineering culture is fast-moving and mostly remote — most staff use their own personal laptops (BYOD) unless they're in a customer-facing role. The company recently raised funding and is adding new cloud services nearly every week.

Asset List

Your team's job is to work through this list — some assets may not be as safe as they seem.

#	Asset
1	Payment processing database (cloud-hosted; stores cardholder data and payment tokens)
2	Core payment API servers (internet-facing cloud VMs)
3	Employee laptops (BYOD; a mix of Mac, Windows, and Linux, with minimal central management)
4	Engineering staging server (mirrors production; used to test new features before release)
5	Customer support ticketing tool (SaaS; stores customer names, emails, and support tickets)
6	Internal team chat workspace (company-wide communications)
7	Marketing analytics dashboard (SaaS; tracks website visitor behavior)
8	An engineer's personal cloud storage account, used informally to share code snippets and CSV data exports with outside contractors

#	Asset
9	Source code repository (private repo, hosted by a third-party git provider)
10	HR/payroll system (SaaS; stores employee SSNs and bank account details)
11	An old prototype payment gateway server from the company's earliest pilot program — still running in a cloud account nobody actively monitors
12	Company handbook and public marketing website content

Regulatory Context

NorthPeak processes cardholder data, so PCI-DSS is the primary regulation. Some of NorthPeak's small-business clients are based in the UK/EU, so GDPR likely applies to those customers' data as well. HIPAA does not apply — NorthPeak does not handle health information.

Worksheet

Complete Parts 1 through 7 below using your assigned scenario. Several parts build on decisions made in earlier parts.

PART 1

Asset & Data Classification

Objectives: L1 Obj. 4 · L3 Obj. 1

Using your scenario's asset list, sort every asset into a category - Hardware, Software, or Data. Some items could reasonably fit more than one category (for example, a database server is hardware that stores data); pick the category you think best fits and be ready to defend it.

Then assign each asset a classification level using the model from Lesson 1: Public, Internal Use Only, Confidential, or Restricted. Note the primary handling requirement that classification implies (e.g., “encrypt at rest and in transit,” “shared drive only,” “no special protection needed”).

#	Asset Name	Category (HW/SW/Data)	Classification Level	Why? (1 sentence)	Handling Requirement
1					
2					
3					
4					
5					
6					
7					
8					
9					
10					

#	Asset Name	Category (HW/SW/Data)	Classification Level	Why? (1 sentence)	Handling Requirement
11					
12					

PART 2

Hardening Recommendations

Objectives: L1 Obj. 1

Choose the THREE assets from your list that most urgently need hardening. For each one, identify what type of resource it is (endpoint, server, or mobile device), list at least two specific hardening techniques from lecture, and explain why you prioritized this asset over the others on your list.

Asset	Resource Type	Hardening Techniques (2+)	Why This Asset Was Prioritized

PART 3

Patch & Configuration Management Plan

Objectives: L1 Obj. 2

Answer the following as a team. Write your responses in the space provided.

a) Secure Baseline

What secure baseline would you build for new employee workstations in this organization? List at least 3 settings or tools it should include.

--

b) Patch Testing & Scheduling

Describe your patch testing and scheduling approach. How would you handle a critical, actively-exploited vulnerability differently than a routine monthly update?

c) Patch Management Tooling

Which patch management tool(s) mentioned in lecture would best fit this organization's size and environment? Explain why.

PART 4**Asset Lifecycle Plan***Objectives: L1 Obj. 3*

Pick ONE asset from your list that is likely to go through a full lifecycle (an employee laptop or workstation is a good choice, but any physical asset works). Map it through all four lifecycle stages, listing at least one concrete action and one security consideration per stage.

Asset selected for this exercise:

Lifecycle Stage	Action(s)	Security Consideration(s)
Procurement & Onboarding		
Configuration & Use		
Monitoring & Support		
End-of-Life (Decommissioning)		

PART 5**Data Protection Controls***Objectives: L3 Obj. 2 · L3 Obj. 3*

For THREE different data assets from your list, decide the right protection approach. In the “Best Technique” column, choose from: Encryption, Hashing, Tokenization, or Data Masking.

Data / Asset	In Transit, At Rest, or Both?	Best Technique	Why This Technique Fits

Where would masking fit?

Identify one place in your scenario where data masking would be appropriate, and explain why encryption or tokenization would not be the right fit there instead.

PART 6

DLP & Shadow IT Strategy

Objectives: L3 Obj. 4 · L1 Shadow IT

a) Find the Shadow IT Risk

Identify the Shadow IT risk hidden in your scenario. Explain why it's a risk to the organization.

b) Propose a DLP Rule

Propose a specific DLP rule or policy that would have caught this risk (or a similar data leak). Be specific about what it should watch for and what action it should take.

c) Recommend a Detection Method

Recommend one detection method — network monitoring, DLP alerting, or application allow-listing — and describe how you'd roll it out without disrupting legitimate work.

PART 7

Regulatory Compliance & EDR Strategy

Objectives: L3 Obj. 5 · L1 Obj. 5

a) Which Regulations Apply?

Which regulation(s) apply to your organization — HIPAA, GDPR, PCI-DSS, more than one, or none? Justify your answer using specific details from your scenario.

b) Required Controls

List two specific controls your organization must implement to meet the regulation(s) you identified.

c) EDR Strategy

Describe how an EDR solution would improve this organization's visibility and incident response. Reference the hidden risk you found in Part 6 — how would EDR have helped catch it sooner?

Final Deliverable: Executive Summary

Write a brief summary (about 150 words) as if you were presenting to your organization's leadership. This is the basis for your group's presentation.

Top 3 Risks You Found

Top 3 Recommended Actions

Grading Rubric

This is a 100-point project. The summary below shows how points are distributed.

Criterion	Points
Part 1 — Asset & Data Classification	15
Part 2 — Hardening Recommendations	15
Part 3 — Patch & Configuration Management	10
Part 4 — Asset Lifecycle Plan	15
Part 5 — Data Protection Controls	15
Part 6 — DLP & Shadow IT Strategy	15
Part 7 — Regulatory Compliance & EDR Strategy	15
Total	100 - Scale (0-4) 0-24=0, 25-59=2, 60-74=3, 75 > = 4